QDB SME Relief Portal — Architecture

Product: QDB SME Relief Portal **Version**: 1.0 **Date**: March 3, 2026 **Status**: Prototype complete — Production architecture planned **Classification**: Confidential — QDB Internal Use Only

Table of Contents

1. Architecture Overview
2. C4 Level 1 — Context Diagram
3. C4 Level 2 — Container Diagram
4. C4 Level 3 — Component Diagram
5. Integration Sequence Diagrams
6. End-to-End Data Flow
7. Data Model — ER Diagram
8. Application State Machine
9. Security Architecture

1. Architecture Overview

The QDB SME Relief Portal is a time-bounded emergency program portal with a hard delivery requirement of 6-8 weeks from brief to live. The architecture is optimised for:

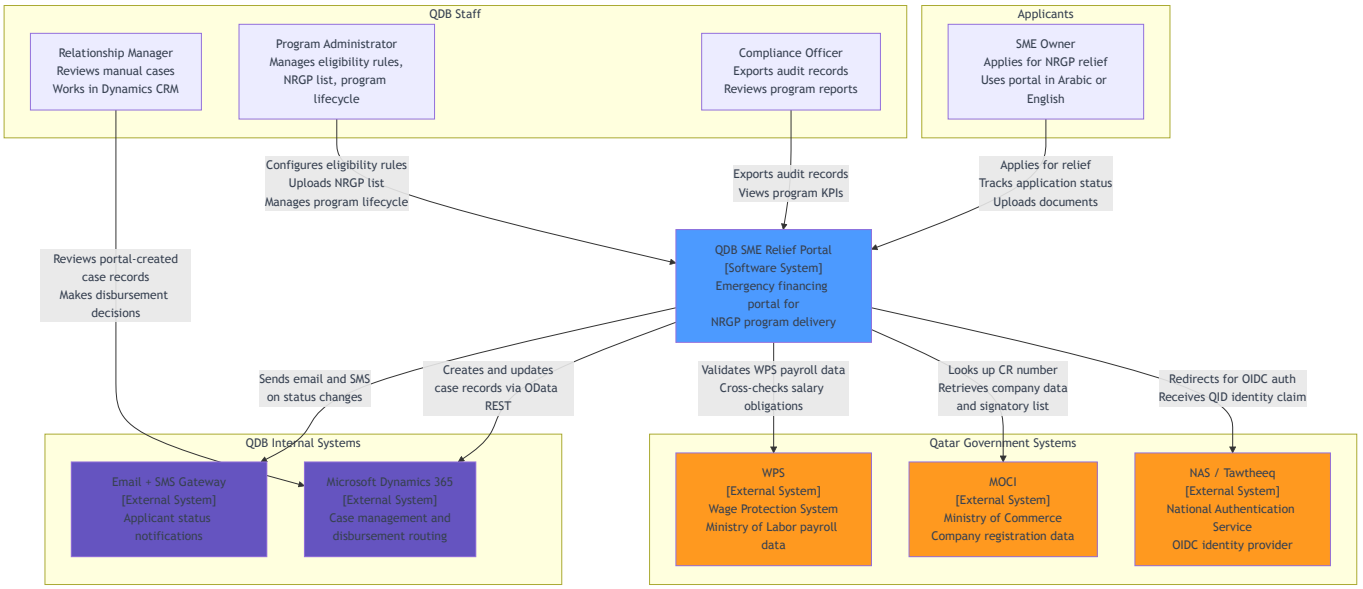
- **Speed of delivery**: Next.js full-stack with server-side rendering; a Fastify API service added in the production phase when real external API integrations are required
- **Government integration**: NAS (OIDC), MOCI (REST), WPS (REST), Dynamics CRM (OData REST) are all existing government/QDB APIs — the portal is an orchestration layer over them
- **Auditability**: Every material decision is captured in an append-only audit table; this is a compliance requirement for a government-administered financial relief program
- **Program sunset**: The architecture supports a defined program window with lifecycle states (Open / Paused / Closed) and automatic enforcement of the program end date

Technology Stack

Layer	Technology	Rationale
Frontend	Next.js 14 + React 18 + Tailwind CSS	SSR for bilingual RTL rendering; ConnectSW standard
Backend API	Fastify 4 (Node.js 20, TypeScript)	High-throughput JSON API; ConnectSW standard
Database	PostgreSQL 15	ACID compliance for audit trail; Prisma ORM
Document storage	S3-compatible object storage	AES-256 at rest; signed URLs; 7-year retention
Auth	NAS/Tawtheeq OIDC + PKCE	Qatar national identity; no passwords stored in portal
CRM	Microsoft Dynamics 365 (OData REST)	QDB's existing case management platform
Ports	Web: 3120, API: 5010	Per ConnectSW PORT-REGISTRY

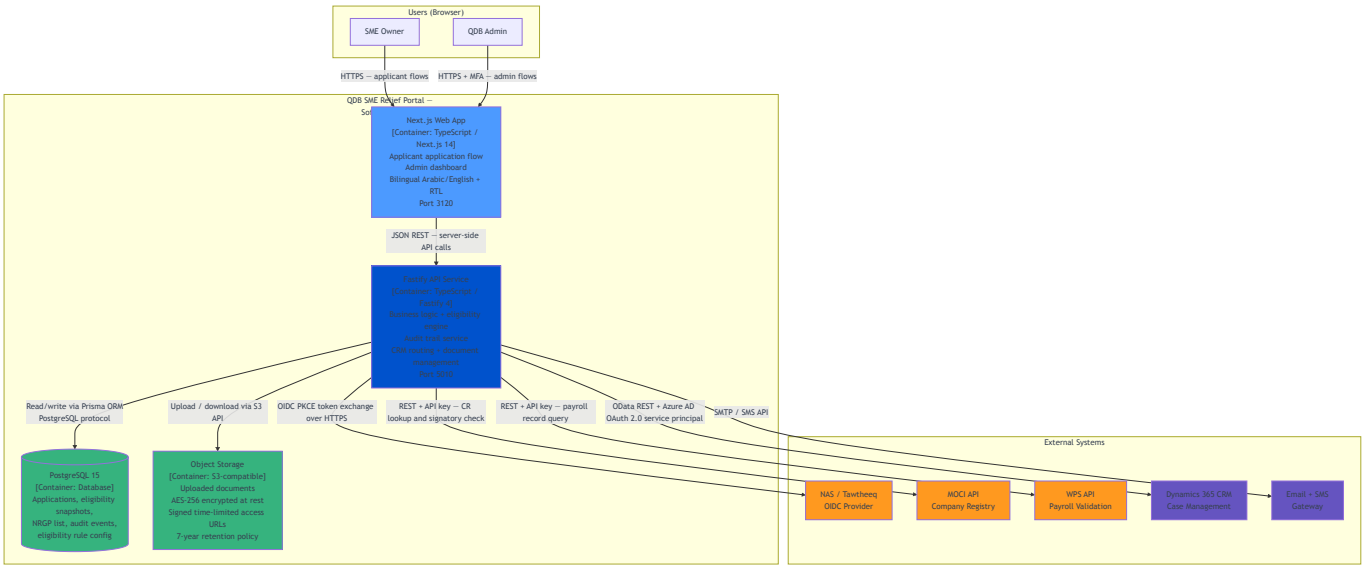
2. C4 Level 1 — Context Diagram

This diagram shows the system in its environment: the people who use it and the external systems it depends on.



3. C4 Level 2 — Container Diagram

This diagram shows the high-level technical building blocks: applications, databases, and storage systems that make up the QDB SME Relief Portal.



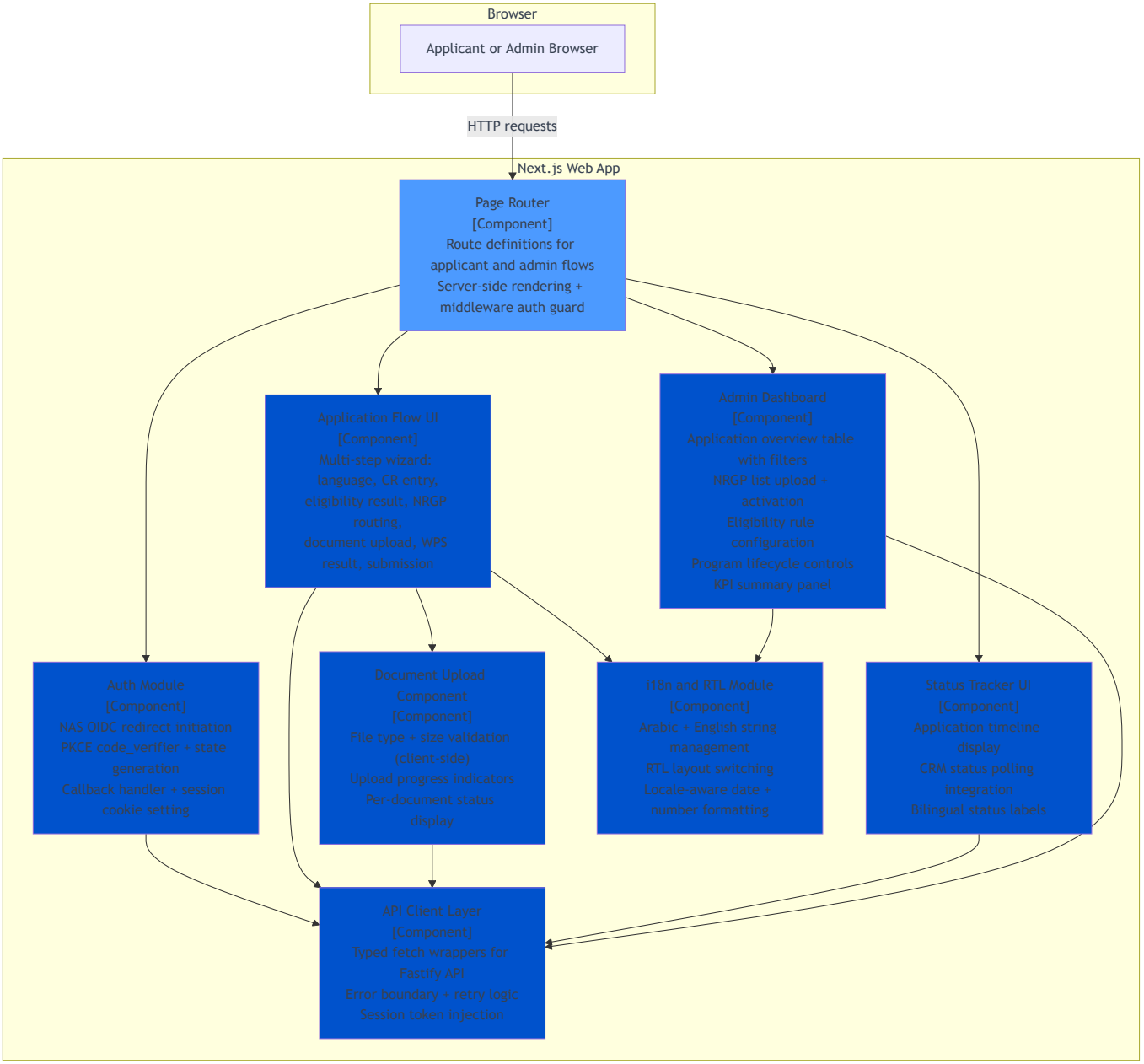
> **Current State**: The prototype consists of the Next.js Web App only (port 3120). All external API calls and the Fastify API Service, PostgreSQL, and object storage are planned for the production build. The prototype mocks all external integrations.

---

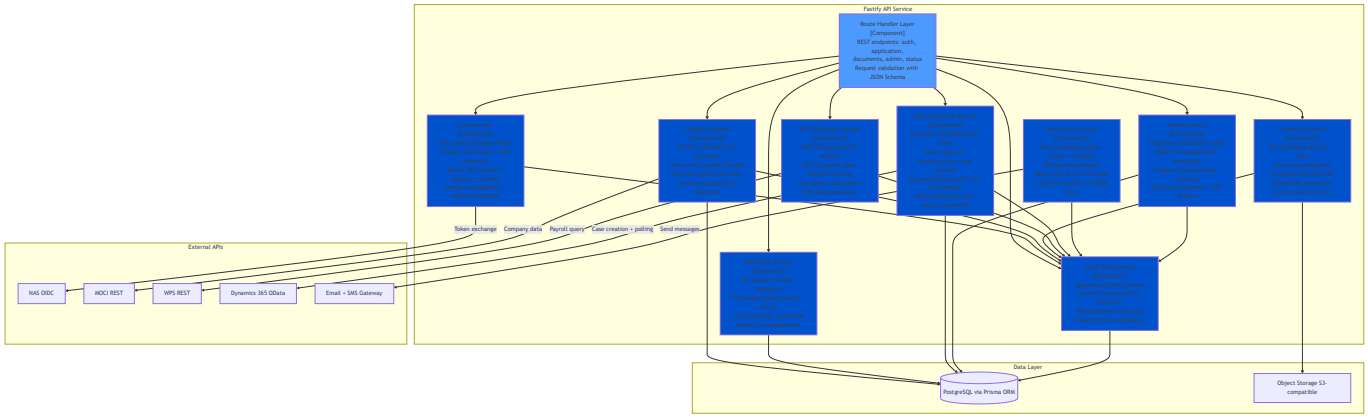
4. C4 Level 3 — Component Diagram

This diagram shows the internal structure of the two primary containers: the Next.js Web App and the Fastify API Service.

4.1 Next.js Web App — Components

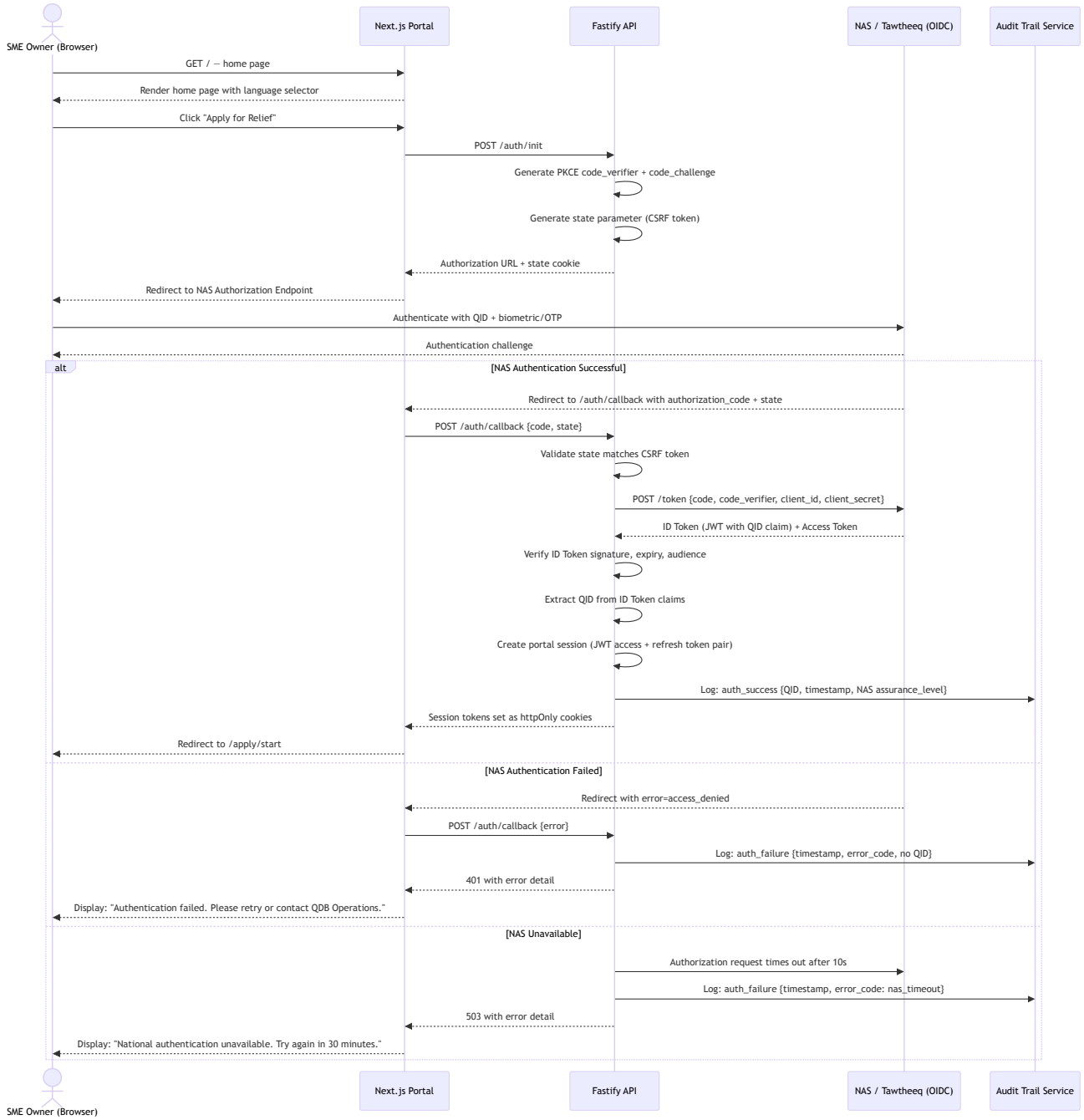


4.2 Fastify API Service — Components



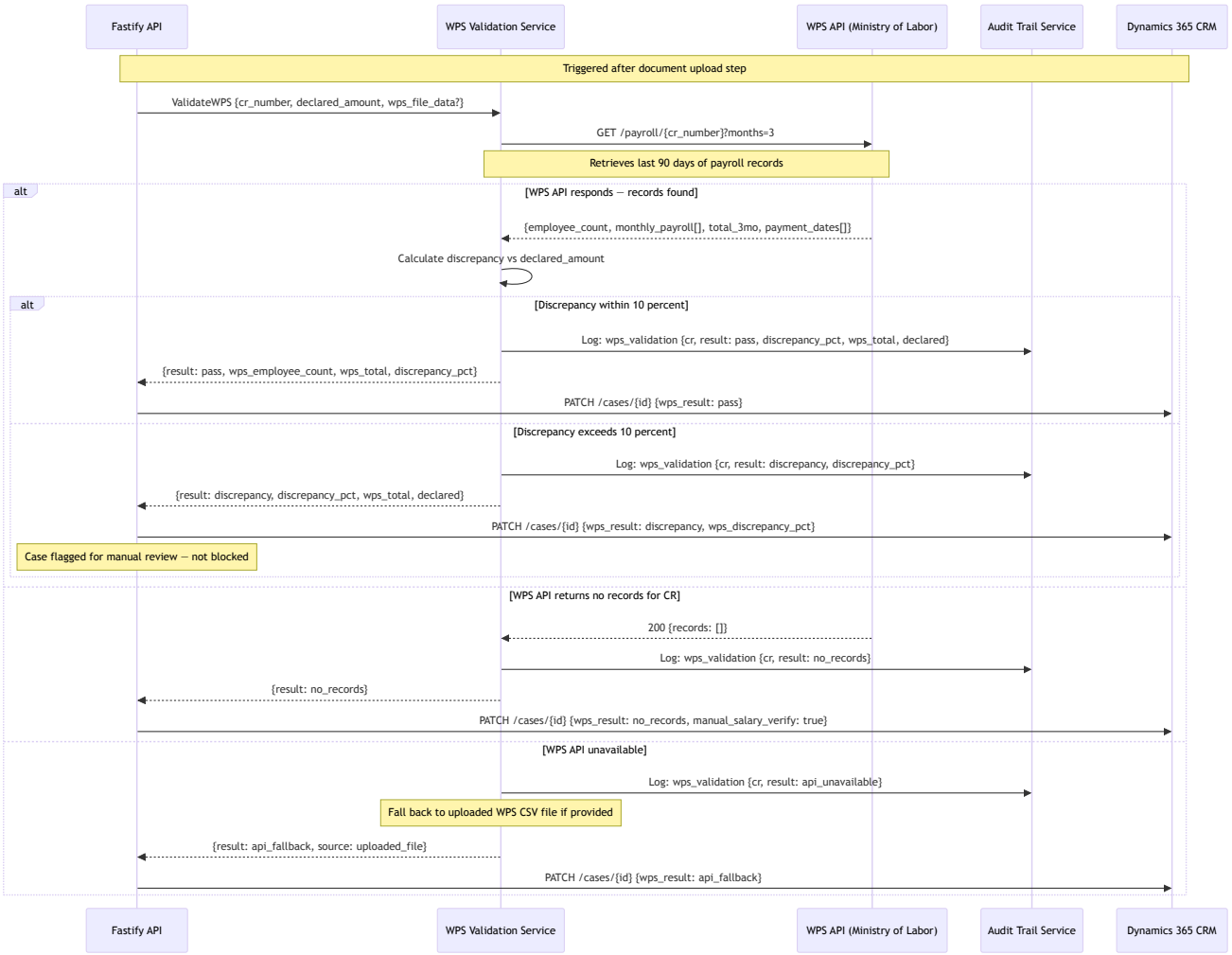
5. Integration Sequence Diagrams

5.1 NAS / Tawtheeq OIDC Authentication

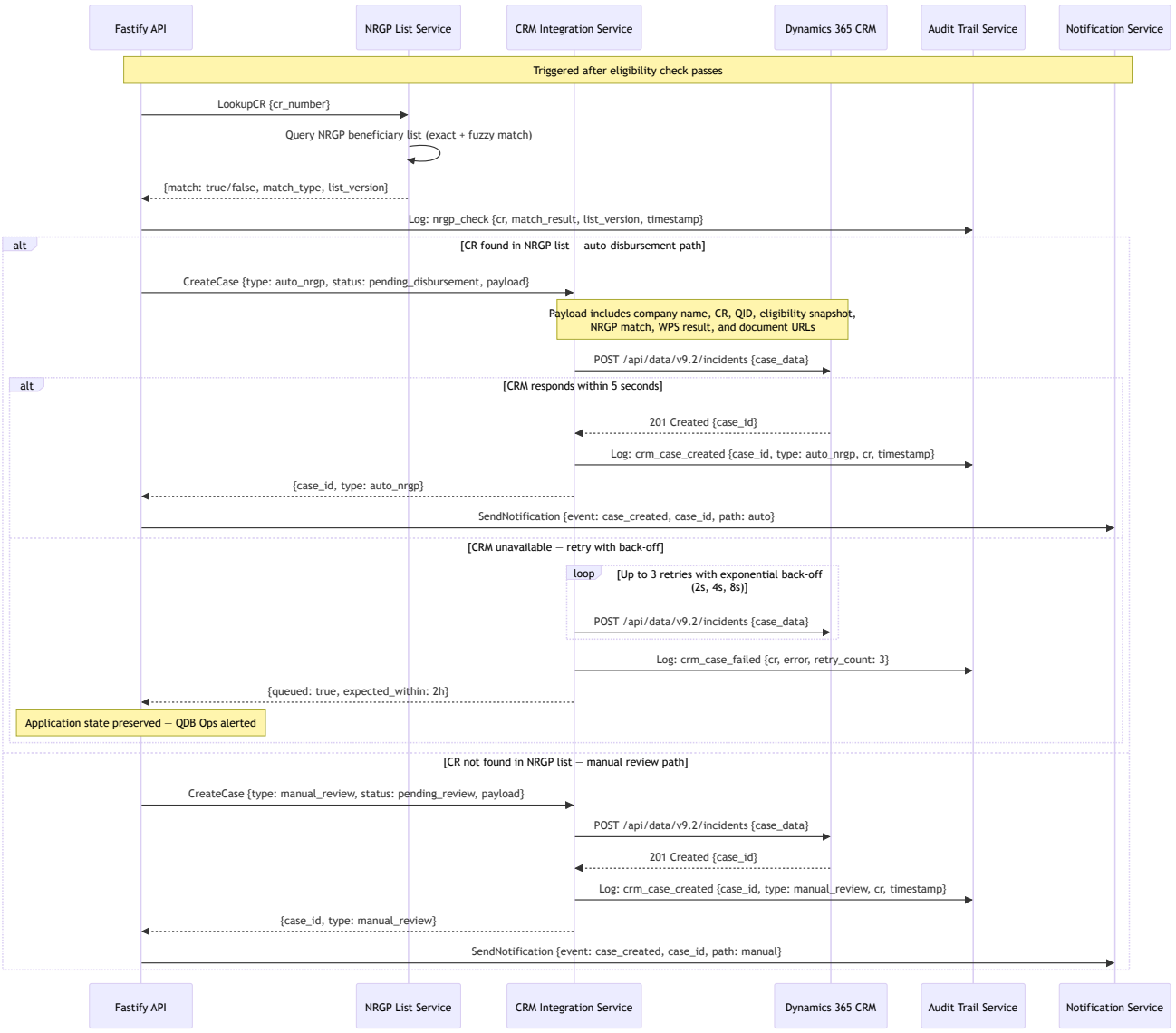


5.2 MOCI Commercial Registration Lookup

5.3 WPS Payroll Validation

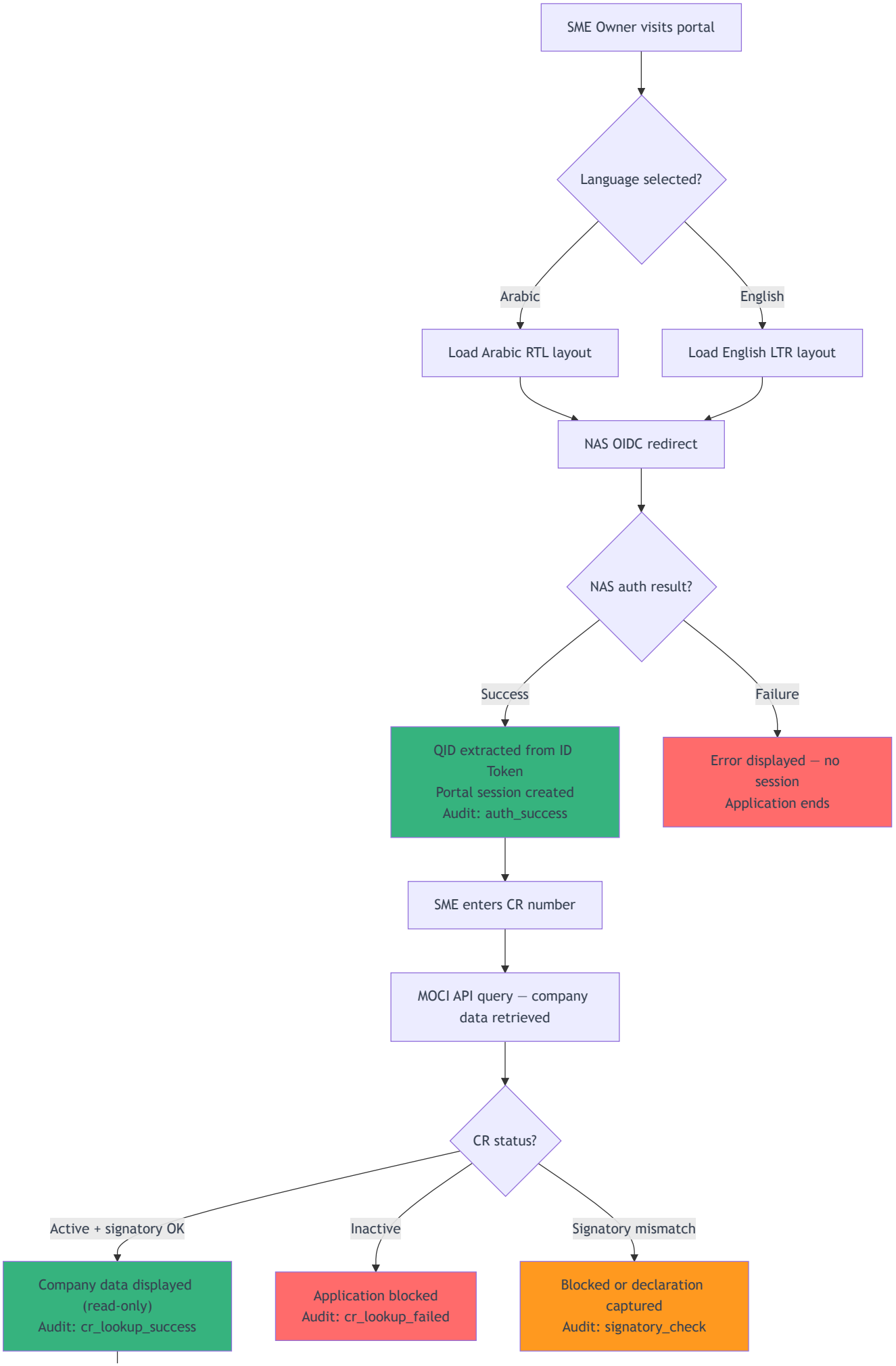


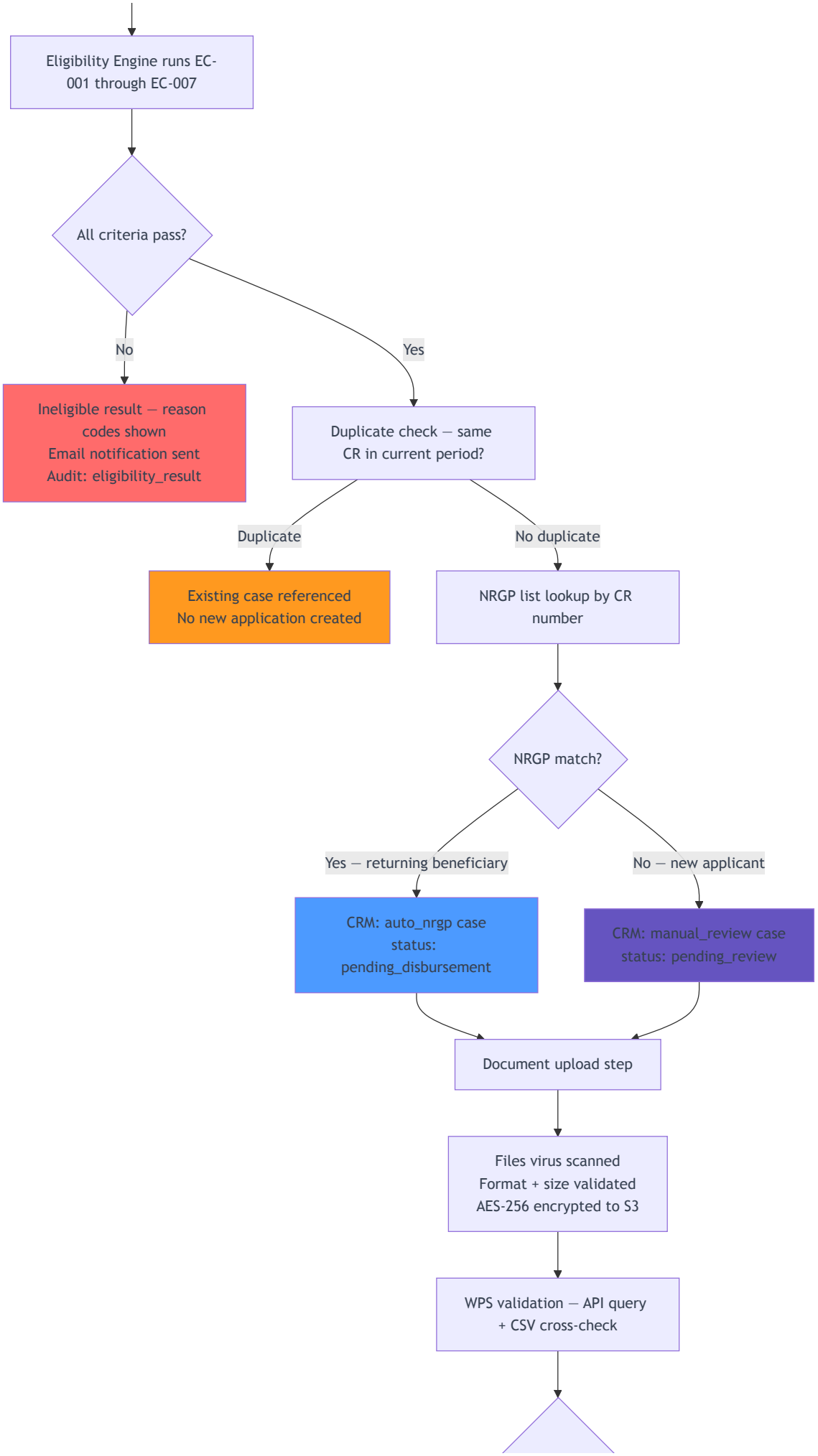
5.4 Dynamics CRM Case Creation and Routing

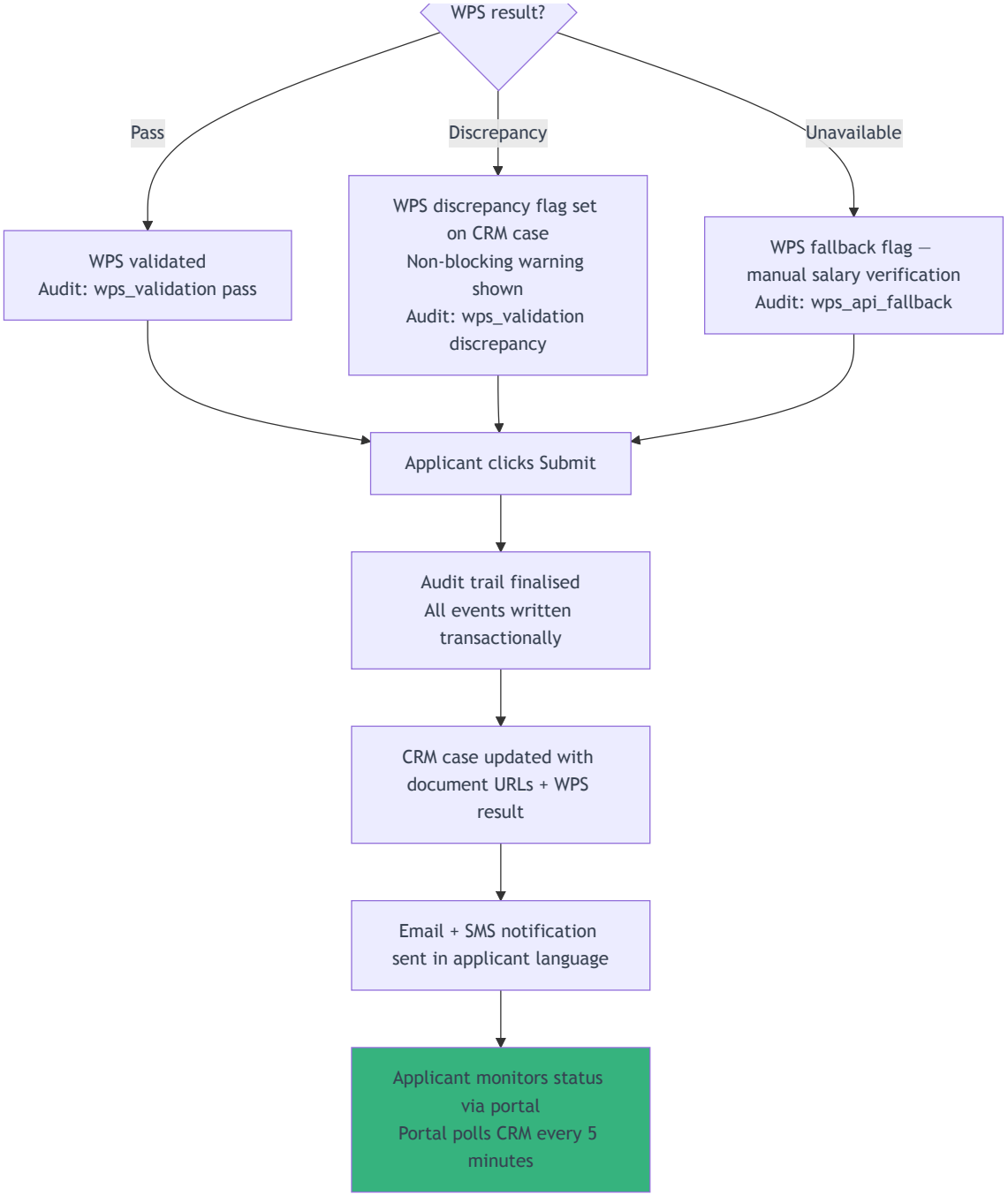


6. End-to-End Data Flow

This diagram shows how data moves through the system from the moment an applicant starts to the point their case is ready for disbursement in Dynamics CRM.


SME Owner visits portal
Language selected?
Arabic
English
Load Arabic RTL layout
Load English LTR layout
NAS OIDC redirect
NAS auth result?
Success
Failure
QID extracted from ID Token
Portal session created
Audit: auth_success
Error displayed — no session
Application ends
SME enters CR number
MOCI API query — company data retrieved
CR status?
Active + signatory OK
Inactive
Signatory mismatch
Company data displayed (read-only)
Audit: cr_lookup_success
Application blocked
Audit: cr_lookup_failed
Blocked or declaration captured
Audit: signatory_check

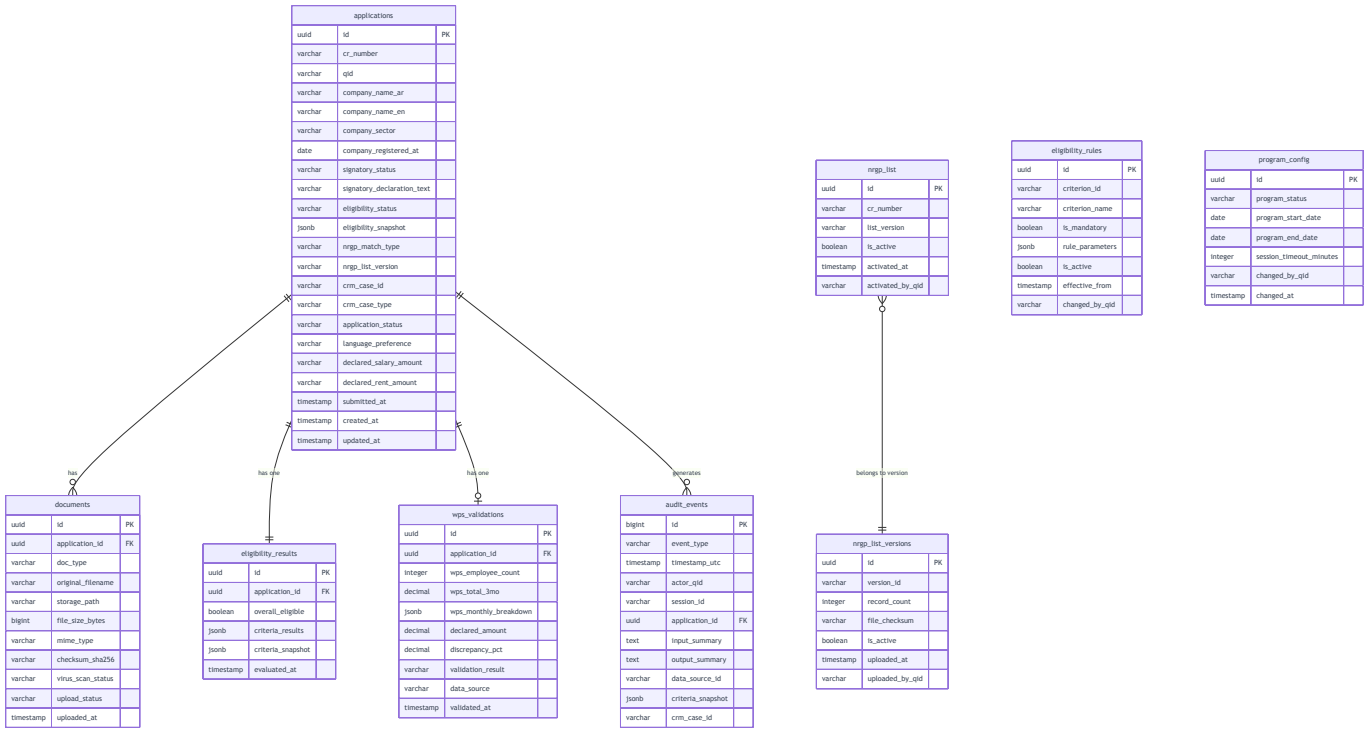

Eligibility Engine runs EC-001 through EC-007
All criteria pass?
No
Yes
Ineligible result — reason codes shown
Email notification sent
Audit: eligibility_result
Duplicate check — same CR in current period?
Duplicate
No duplicate
Existing case referenced
No new application created
NRGP list lookup by CR number
NRGP match?
Yes — returning beneficiary
No — new applicant
CRM: auto_nrgp case status: pending_disbursement
CRM: manual_review case status: pending_review
Document upload step
Files virus scanned
Format + size validated
AES-256 encrypted to S3
WPS validation — API query + CSV cross-check



---

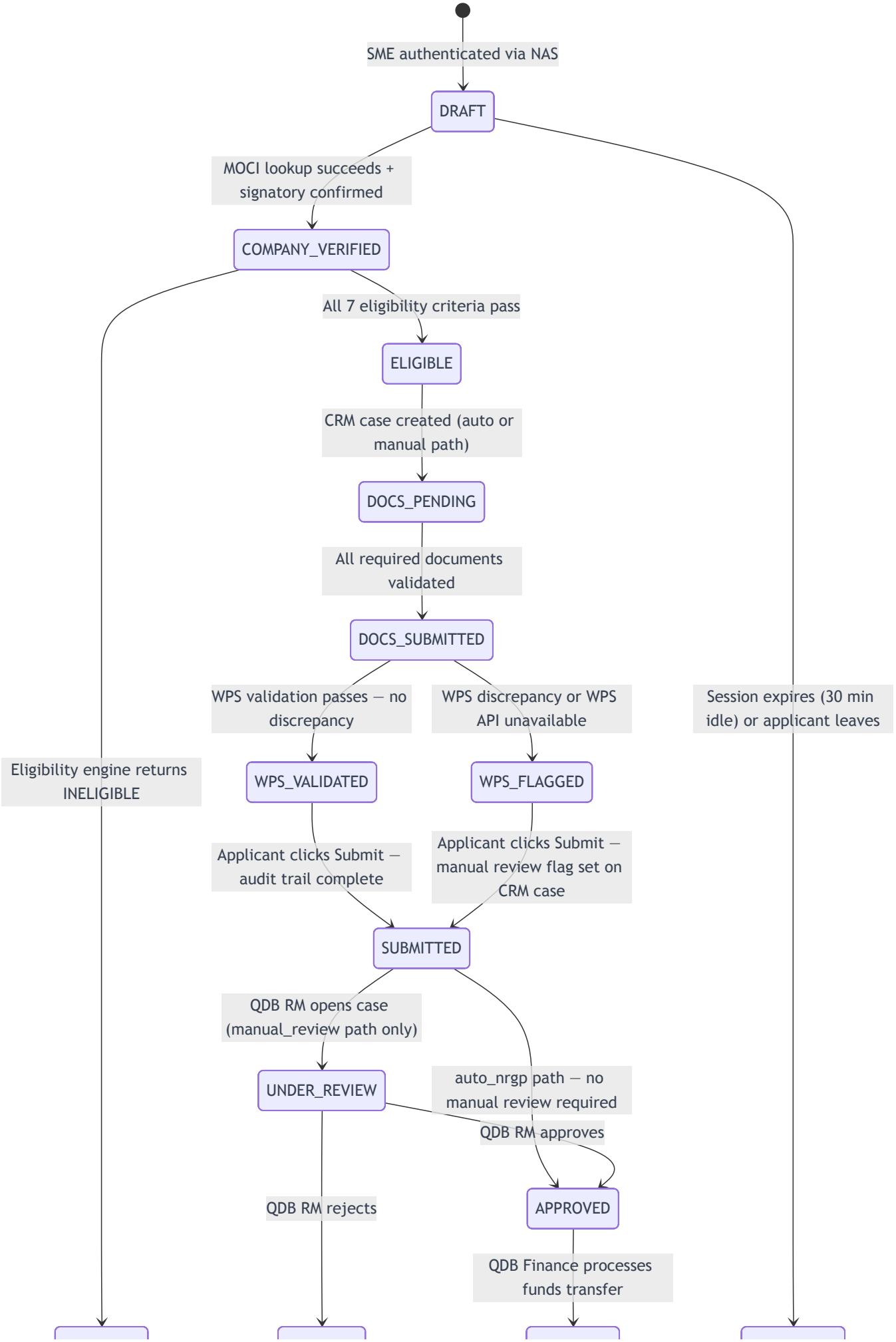
7. Data Model — ER Diagram

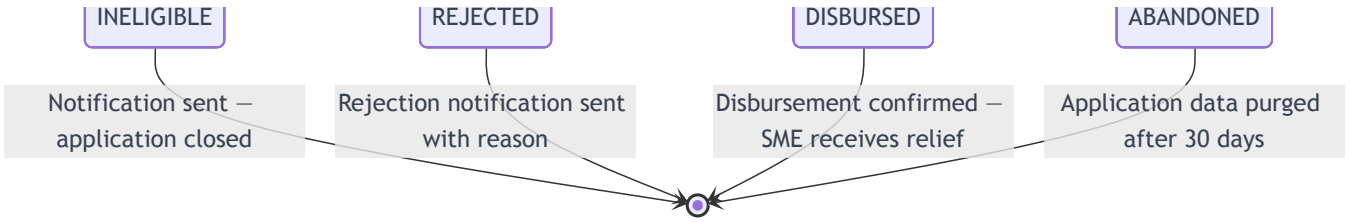
The planned PostgreSQL data model for the production system. All tables use UUID primary keys except `audit_events` which uses sequential IDs for ordered export.



8. Application State Machine

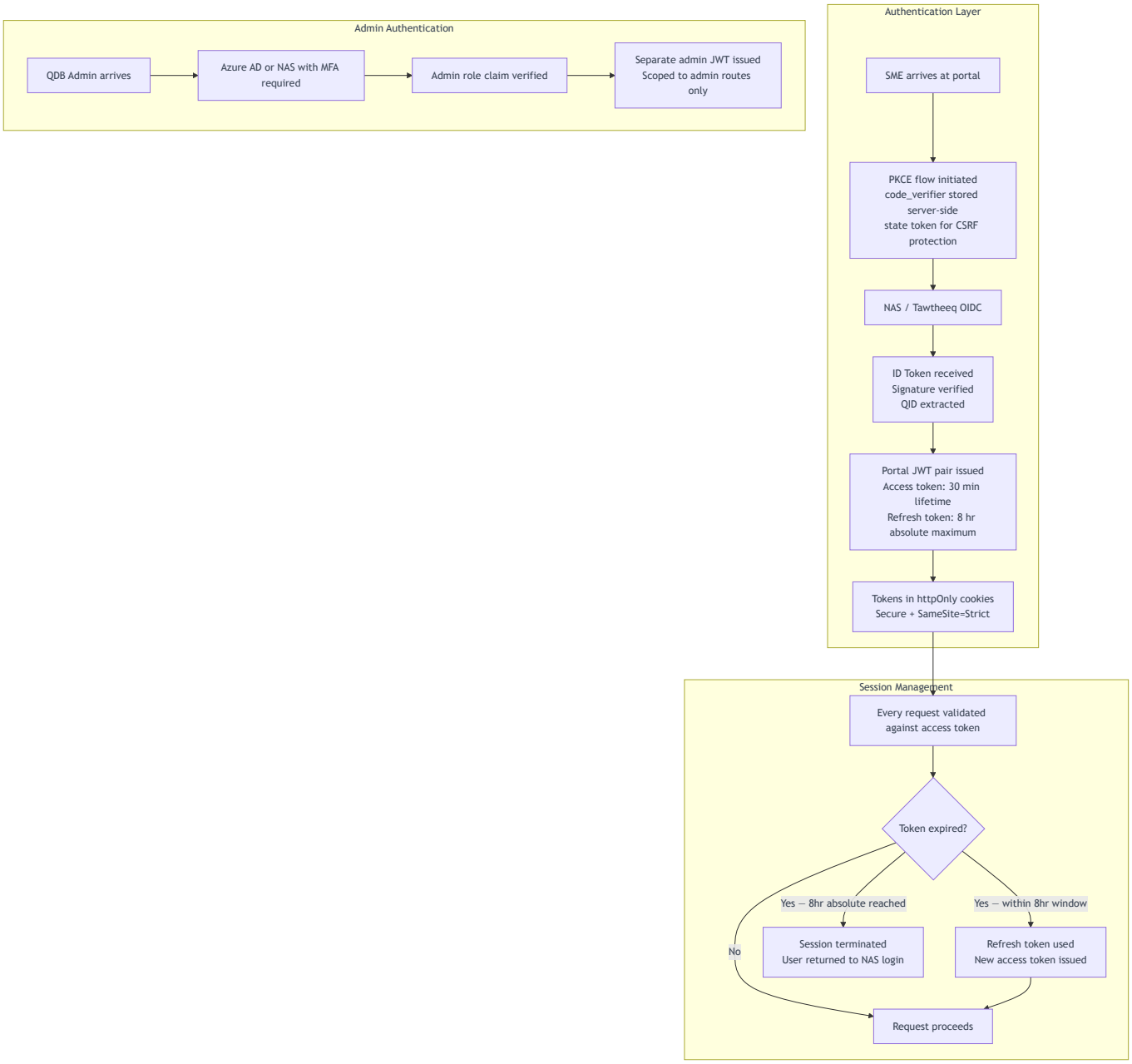
An application moves through a defined set of states from draft to final outcome. State transitions are enforced by the API and recorded in the audit trail at every step.


SME authenticated via NAS
DRAFT
MOCI lookup succeeds + signatory confirmed
COMPANY_VERIFIED
All 7 eligibility criteria pass
ELIGIBLE
CRM case created (auto or manual path)
DOCS_PENDING
All required documents validated
DOCS_SUBMITTED
WPS validation passes — no discrepancy
WPS discrepancy or WPS API unavailable
Session expires (30 min idle) or applicant leaves
Eligibility engine returns INELIGIBLE
WPS_VALIDATED
WPS_FLAGGED
Applicant clicks Submit — audit trail complete
Applicant clicks Submit — manual review flag set on CRM case
SUBMITTED
QDB RM opens case (manual_review path only)
UNDER_REVIEW
auto_nrgp path — no manual review required
QDB RM approves
QDB RM rejects
APPROVED
QDB Finance processes funds transfer



9. Security Architecture

9.1 Authentication and Session Management

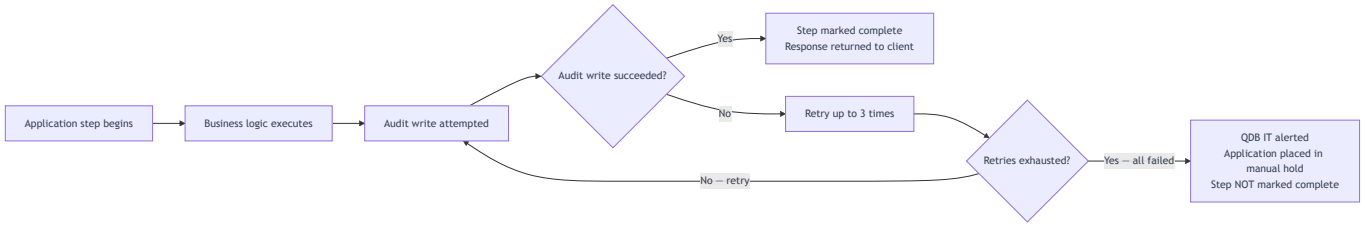


9.2 Document Security Model

Layer	Control	Implementation
Transport	TLS 1.3 minimum	All HTTP requests rejected and redirected to HTTPS
Storage encryption	AES-256 at rest	Applied before write, verified on read
Key management	KMS — not co-located with data	Keys rotated per KMS policy
Access URLs	Signed, time-limited	1-hour expiry; scoped to requesting user's case
Virus scanning	Pre-activation scan	Files quarantined on detection; applicant notified
Retention	Enforced at storage tier	7-year minimum per QDB policy and Qatar PDPA
Role-based access	Applicant: own docs only	QDB staff: all docs by case; Audit: read-only export

9.3 Audit Trail Integrity

The audit trail is a core compliance requirement for a government-administered financial relief program. Its integrity is enforced at multiple levels.



Database-level protections on `audit_events`:

- `REVOKE UPDATE, DELETE ON audit_events FROM application_role` — the application service account cannot modify or delete audit records
- Only the append-only writer role holds INSERT permissions
- Any direct UPDATE or DELETE attempt against the audit table triggers a monitoring alert
- Full export available to the Compliance Officer via admin API as JSON or CSV, in chronological order with criteria snapshots

9.4 Rate Limiting and Fraud Controls

Control	Rule	Enforcement
Application rate limit	Max 3 attempts per CR per 24 hours	API-level rate limiter keyed on CR number
Duplicate detection	One active application per CR per program period	Eligibility engine check before NRGP lookup
Document URL forgery	Signed URLs with 1-hour TTL	S3 pre-signed URL with HMAC signature
Admin brute force	MFA required; account lockout after 5 failed attempts	Azure AD or NAS policy
Session fixation	New session ID issued after NAS auth callback	PKCE state parameter invalidated after use
CR format injection	Strict 10-digit numeric validation	Client and API-level schema validation

9.5 Qatar PDPA Compliance

Requirement	Implementation
Data minimisation	MOCI company data not persisted beyond session; only summary stored in DB
Purpose limitation	Data collected solely for NRGP application processing
Retention limits	7-year minimum; automated purge policy after retention period
Data subject access	Applicant can view own application data and status via the portal
Consent	Explicit consent captured at application start and recorded in audit trail
Cross-border transfers	All data stored within Qatar or QDB-approved jurisdiction
PDPA impact assessment	Required before production launch (NFR-011) — must be signed off by DPO